

CANADIAN LEGAL CHECKLIST

Everything ONYX Ledger needs to be aware of to launch and operate a tax-filing product in Canada · August 2026

How to read this: each item says **what it is**, **when it applies to you**, and **what to do**, in plain language. Tags: **MUST** = legally required before or at launch · **CONDITIONAL** = required only if you do a specific thing · **STRONGLY ADVISED** = not strictly law, but expected in this industry and dangerous to skip.

This document is a roadmap, not legal advice — before launch, have a Canadian tech/privacy lawyer review your setup (budget roughly \$5k–\$15k for the initial pass).

1. SETTING UP THE COMPANY

1.1 Incorporate **MUST**

- **What:** Create a corporation so the company — not you personally — carries the legal risk of handling people's tax data.
- **Why it matters here:** in this business a single mistake (bad advice, data breach) can create large claims. Never run this as a sole proprietorship.
- **What to do:** Federal incorporation (CBCA) is the usual choice for a startup that will operate across provinces — then register extra-provincially in the provinces where you operate. Cost is small (a few hundred dollars plus legal fees). Get a shareholders' agreement between founders (who owns what, what happens if someone leaves) and make sure every founder and contractor signs an **IP assignment** so the company owns the code.

1.2 CRA business accounts **MUST**

- **What:** A Business Number (BN), plus program accounts: GST/HST, payroll (once you pay anyone), corporate income tax.
- **GST/HST detail:** you must register and charge GST/HST once revenue passes \$30,000 in four consecutive quarters — but register early anyway; it lets you recover the tax you pay on your own expenses. Note you'll charge different rates by customer province (5%–15%), and Quebec's QST is administered separately by Revenu Québec.

1.3 Name and trademark **STRONGLY ADVISED**

- **What:** A NUANS/name search before incorporating, and a trademark application for "ONYX Ledger" with CIPO.
- **Why:** trademarks in Canada take ~2+ years to register, so file early. Also check the name doesn't collide with existing financial brands (Onyx is a common fintech name — search before you commit).

- **One trap:** never use CRA logos, colours, or anything implying government affiliation. Your existing "not affiliated with the CRA" disclaimer is correct — keep it prominent.

2. PERMISSION TO ACTUALLY FILE TAXES

2.1 NETFILE software certification **MUST** (to let users file for themselves)

- **What:** CRA approval of your software, earned by passing their test returns each year. Covered in detail in the pros/cons document.
- **Key legal points:** you sign a **confidentiality agreement with the CRA** (to receive draft forms — treat those as strictly secret), you must re-certify **every year**, and you may only advertise as "NETFILE certified" for the years/products actually certified. Advertising certification you don't have is misleading advertising (see §5).

2.2 EFILE registration **CONDITIONAL**

- **What:** A separate CRA program for people/companies who file returns **on behalf of** clients (the way an accountant does), including a suitability screening of the business and its principals.
- **When it applies:** only if you ever offer "we file it for you" or human-assisted filing. Pure self-serve software (user presses File themselves) needs NETFILE certification, not EFILE.

2.3 Quebec — Revenu Québec certification **CONDITIONAL**

- **What:** Quebec residents file a second, separate provincial return (TP1) with Revenu Québec, which runs its own software certification.
- **When it applies:** only if you serve Quebec filers. If you launch rest-of-Canada first, you must clearly say Quebec returns aren't supported — don't let a Quebec user get halfway through.

2.4 Authorized access to client CRA data **CONDITIONAL**

- **What:** Using CRA Auto-fill My Return or Represent a Client to pull a user's slips requires the user's proper authorization through CRA's own consent flow, and your software must follow CRA's rules for those services.
- **What to do:** never ask users for their CRA My Account password. Access flows through CRA's official login/authorization only. Storing or replaying CRA credentials would be both a privacy violation and a fast way to get banned.

3. PRIVACY LAW — THE BIGGEST ONGOING OBLIGATION

You will hold **SINs, incomes, investments, and medical expense data**. That is close to the most sensitive commercial data set that exists in Canada. Privacy compliance is not a page on your website; it is a set of ongoing legal duties with real penalties (Quebec's can reach the millions or a % of worldwide revenue).

3.1 PIPEDA — the federal privacy law **MUST**

- **What:** Canada's main private-sector privacy law. Applies to you everywhere except (for intra-provincial matters) provinces with their own equivalent laws (Quebec, Alberta, B.C.).
- **Your core duties in plain terms:**
 - **Meaningful consent** — tell people clearly what you collect and why, before you collect it. Sensitive data (all of yours) requires express, not implied, consent.
 - **Collect only what you need** — if the CRA can re-fetch a slip, question whether you need to store a copy at all.
 - **Use it only for the stated purpose** — using tax data to market other products, or feeding it to an AI model for training, needs its own separate consent. This is the mistake that would end the company.
 - **Safeguard it** — security proportional to sensitivity (yours = maximum: encryption, access controls, logging).
 - **Breach duties** — you must keep records of every breach, and report breaches posing "real risk of significant harm" to the Privacy Commissioner and to affected users. A tax-data breach will essentially always meet that bar.
 - **Access & deletion** — users can demand to see their data and have it corrected; honour deletion where you're not legally required to retain.
 - **Accountability** — you must formally designate a privacy officer. At your size, a founder wears this hat, in writing.

3.2 Quebec Law 25 **CONDITIONAL** (but plan for it)

- **What:** Quebec's modernized privacy law — the strictest in Canada, with the biggest fines.
- **When it applies:** the moment you serve Quebec residents, even without an office there.
- **What it adds beyond PIPEDA:** a named privacy officer published on your site; **privacy impact assessments** (including one before sending personal data outside Quebec — relevant if your servers or AI providers are in the U.S.); privacy-by-default settings; the right to data portability; and — directly relevant to you — **transparency duties for automated decisions:** if a decision about a person is made purely by automated means, you must tell them and let them ask questions or object. Your Tax Health Score and AI recommendations should be built with this in mind from day one.

3.3 SIN handling **MUST**

- **What:** The Social Insurance Number has special federal guidance: collect it only when legally required (tax filing qualifies), never use it as your own customer ID, restrict internal access, encrypt it, and never display it in full in the UI, emails, or support tools.

3.4 Where the data lives **STRONGLY ADVISED**

- **What:** No federal law forces tax data to stay in Canada, but if personal data is stored or processed outside Canada (U.S. cloud regions, U.S.-based AI APIs) you must disclose it, assess the risk (mandatory assessment under Law 25 for Quebec), and put contracts (data processing agreements) in place with every vendor that touches the data — cloud host, AI provider, analytics, support tooling, payment processor.
- **Practical advice:** just use Canadian regions (AWS/Azure/GCP all have them) and Canadian-region AI endpoints where possible. It removes a whole category of questions from users, enterprise partners, and regulators.

3.5 Records retention **MUST**

- **What:** Tension to manage: privacy law says delete what you don't need, but tax records have expected retention (CRA's general reassessment window is ~3 years, records guidance is 6 years, and users expect old returns to stay available). Write a retention schedule: what you keep, for how long, and what "delete my account" actually deletes vs. archives — and say so honestly in the privacy policy.

4. SECURITY OBLIGATIONS

- **Legal baseline MUST:** PIPEDA/Law 25 require safeguards proportional to sensitivity — for you that means encryption in transit and at rest, MFA on user accounts, role-based internal access, audit logging, and an incident-response plan you've actually rehearsed. Your demo already promises these publicly; a promise on your website is legally enforceable as a representation, so ship what the security page says.
- **SOC 2 Type II STRONGLY ADVISED:** not law, but the de-facto ticket to being taken seriously with financial data. Start the audit clock early (Type II needs months of evidence).
- **PCI-DSS CONDITIONAL:** applies when you take card payments. Use Stripe/hosted checkout so card data never touches your servers — that keeps you in the lightest compliance tier.

5. MARKETING AND SELLING — THE RULES MOST STARTUPS BREAK FIRST

5.1 CASL — anti-spam law MUST

- **What:** Canada's anti-spam law, among the strictest in the world. You need **consent before** sending commercial email/SMS, every message needs your identity and a working unsubscribe, and penalties run to the millions.
- **Direct impact on your funnel:** the Tax Health Score email-capture flow must include a clear, unchecked-by-default consent checkbox for marketing, and you must keep proof of every consent (who, when, how). Transactional messages ("your return was filed") are fine; "upgrade to Pro" emails need consent.

5.2 Competition Act — truth in advertising MUST

- **What:** False or misleading claims about a product are illegal, with serious penalties — and the law now explicitly targets **drip pricing** (advertising a price that grows with mandatory fees at checkout).
- **Direct impact on you:** the demo's "\$2,431 refund" and "+\$420 found" style numbers may not appear in marketing as if typical or guaranteed. "Maximum refund guaranteed" claims need a real, honoured guarantee behind them. "\$29.99" must be the actual total (plus tax only). "Free" must actually be free — no forced upgrade to complete a basic return that was advertised as free (this exact pattern has drawn U.S. regulatory action against TurboTax; assume Canada's Competition Bureau noticed).

5.3 Provincial consumer protection MUST

- **What:** Each province regulates consumer contracts. The parts that bite subscription software: clear pre-purchase disclosure of total price and terms, rules for **auto-renewal** (disclose it clearly; some provinces require renewal reminders), easy cancellation, and refund rights for misrepresented services. Quebec's Consumer Protection Act is the strictest — many contract clauses (e.g., some liability waivers) simply don't work against Quebec consumers.

- **What to do:** one compliant-everywhere design: show total price before payment, plain-language renewal terms, one-click cancel, email receipts.

5.4 Your legal documents **MUST**

- **Terms of Service:** written for this product specifically — what the service is and is not (software, not professional tax advice), user responsibilities (accuracy of what they enter), limitation of liability, dispute terms. Don't copy a generic SaaS template; the "not advice" architecture is your main liability shield and must be consistent across ToS, UI, and marketing.
- **Privacy Policy:** must reflect what you actually do (see §3) — a policy that overpromises is itself a misleading representation.

6. MONEY-ADJACENT RULES (EASY TO STUMBLE INTO)

- **Tax Rebate Discounting Act** **CONDITIONAL**: a specific federal law regulating anyone who gives clients an instant/advance refund in exchange for their actual CRA refund. It caps what you can charge and imposes registration. Applies only if you ever offer "get your refund today" — if you do, read this law first; if not, ignore it.
- **FINTRAC / money services** **CONDITIONAL**: if you ever hold or move client money (receiving refunds on behalf of users, wallets, paying tax bills for users), you likely become a Money Services Business with registration and anti-money-laundering duties. Filing software that never touches the refund itself does not trigger this. Design decision: **don't touch the money** unless it's a deliberate, lawyered strategy.
- **Your own taxes** **MUST**: corporate T2 returns, GST/HST remittance, payroll withholding once you have employees. A tax startup that's late on its own taxes is a bad headline.

7. GIVING "ADVICE" AND LIMITING LIABILITY

- **Good news**: tax preparation is not a licensed profession in Canada — you don't need to be a CPA to sell tax software or preparation. **But**: you may not use protected titles ("Chartered Professional Accountant," "CPA") or imply professional accounting services you don't provide; and only lawyers can provide legal services, so keep the product clearly on the "information and calculation" side of the line, never "legal opinion."
- **Negligence still applies** **MUST**: no licence needed doesn't mean no liability. If your engine mis-calculates or your AI gives wrong guidance and a user is reassessed with penalties, you can be sued for negligent misrepresentation. Your defences are: accuracy (test the engine relentlessly), honest framing (educational estimates, user reviews before filing), disclaimers (necessary but not sufficient — courts look at the whole picture), and insurance.
- **Insurance** **STRONGLY ADVISED**: before real users: **Errors & Omissions** (covers claims that your software/guidance was wrong — many competitors also market an "accuracy guarantee" backed by this), **Cyber liability** (breach response costs, notification, credit monitoring), and standard **CGL + Directors & Officers**. Disclose your AI features to the insurer explicitly — an undisclosed AI advice feature can void coverage.
- **The AI copilot specifically**: no dedicated AI statute exists in Canada today (the proposed AIDA died in January 2025 and hasn't returned; the government has signalled any future law will be a new design). That means your AI is governed by everything above — privacy law, consumer protection, misleading advertising, negligence. Practical rules: label AI answers as AI; cite CRA sources; keep humans/deterministic calculators in the loop for anything that changes a filing; log every AI interaction; and never let the model see more personal data than the question needs.

8. QUEBEC — DECIDE, DON'T DRIFT

- Serving Quebec adds, on top of everything above: **TP1 certification** with Revenu Québec (§2.3), **Law 25** privacy duties (§3.2), the **Charter of the French Language (Bill 96)** — product, contracts, and support in French, with French versions at least equal to English — Quebec's stricter **Consumer Protection Act**, and **QST** registration.
- Roughly: Quebec ≈ a second country for compliance purposes, holding ~22% of Canadian filers. Launching rest-of-Canada first is legitimate — but geo-detect and clearly turn away Quebec filers until you're ready, and don't market in Quebec before then.

9. PEOPLE AND ACCESSIBILITY

- **Hiring CONDITIONAL:** once you hire: payroll registration and source deductions, provincial employment standards (hours, vacation, termination notice), workers' compensation registration where required, and written contracts with IP assignment + confidentiality for every employee and contractor. Be careful classifying "contractors" who work like employees — CRA reassesses that.
- **Accessibility STRONGLY ADVISED:** Ontario's AODA imposes WCAG accessibility on larger organizations, and accessible design is increasingly expected (and litigated) generally. Building to WCAG 2.1 AA from the start is far cheaper than retrofitting — and tax software has many elderly and disabled users.

10. THE ONGOING COMPLIANCE CALENDAR

When	What
Every year, ~Nov–Feb	NETFILE re-certification against new CRA test returns (+ Revenu Québec if in Quebec); update engine for that year's tax changes
Every year	Corporate annual return; T2 corporate tax filing; insurance renewals (re-disclose product changes, especially AI features)
Monthly/quarterly	GST/HST (and QST) remittance; payroll remittances
Continuous	Breach log; CASL consent records; privacy requests (access/deletion) within statutory deadlines; keep ToS/Privacy Policy matching actual practice every time the product changes
Each new feature	Quick legal screen: does it touch new data (privacy assessment)? move money (§6)? make claims (§5.2)? make automated decisions (Law 25)?
Watch list	Federal privacy-law reform and any new AI legislation (both signalled as priorities, neither passed as of mid-2026); CRA's expansion of automatic filing

11. PRIORITY ORDER — IF YOU DO THINGS IN SEQUENCE

Phase 1 — before anything public: incorporate + shareholders' agreement + IP assignments; BN/GST-HST; ToS + Privacy Policy written for this product; CASL-compliant signup; truthful marketing copy (kill fake precision); name a privacy officer.
--

Phase 2 — before holding real tax data: full PIPEDA safeguard build-out (encryption, MFA, access logs, breach plan, retention schedule); vendor DPAs; Canadian data residency; E&O + cyber insurance; SIN-handling rules implemented.

Phase 3 — before filing anything: NETFILE certification cycle; accuracy-testing regime for the engine; "review before you file" UX; accuracy guarantee terms (if offered).

Phase 4 — deliberate expansions, each with its own legal work: Quebec (TP1 + Law 25 + French); assisted filing (EFILE); refund advances (Tax Rebate Discounting Act); anything touching client money (FINTRAC analysis first).

Prepared as an internal planning document, August 2026. This is an orientation map, not legal advice; laws summarized here (especially Quebec Law 25 details, Competition Act amendments, consumer-protection rules per province, and the status of federal privacy/AI reform) change and should be verified with a Canadian lawyer before each launch phase.